Information System Security Plan

1. Information System Name/Title:
    a. Cloud File Sharing System CFSS
2. System Categorization
    a. Confidentiality Impact: Moderate
        i. Data breaches in the CFSS could have devastating consequences for the company. Personal information (PII), financial data, and data that is sensitive to the company are all stored in the system. Reputational harm, a decline in customer trust, and privacy issues could result from this information leaking out. The effect on business operations, however, will likely not be disastrous.
    b. Integrity Impact: Moderate
        i. The organization would be severely affected if the CFSS data were corrupted. The legitimacy, efficiency, and accuracy of the business might be compromised if client deliverables, internal documents, or financial records were falsified or altered. It is not believed that these consequences will significantly or catastrophically affect the organization's core activities.
    c. Availability Impact: Moderate
        i. Cloud File Sharing System (CFSS) downtime would have devastating consequences for the company. Delays in project execution and decreased operational efficiency would result from users not being able to access important files and cooperate efficiently. But there would be other ways for the group to keep running, so it wouldn't be a total disaster.
    d. SC CFSS = {(confidentiality, MODERATE), (integrity, MODERATE), (availability, MODERATE)}
3. System Description / Purpose
    a. The Cloud File Sharing System (CFSS) is a Software as a Service (SaaS) platform used by the organization to securely store, access, and share digital files and documents. The system serves as a centralized repository for business and client-related data, enabling collaboration among employees and project teams across all departments.
    b. The CFSS supports daily operations by allowing users to upload, retrieve, and share files internally and externally with clients through secure methods. The system is critical to business operations, as it replaces traditional file storage and email-based file sharing, and is relied upon for ongoing project work and document management.
4. System Ownership

    a. System ownership for the Cloud File Sharing System (CFSS) is shared between business and technical stakeholders. The Director of Operations serves as the business owner and is accountable for the system's effectiveness in supporting organizational operations.
    b. The IT Infrastructure Manager serves as the technical owner and is responsible for overseeing the system's configuration, availability, and overall performance. Day-to-day system operations are managed by the IT administration team, which is responsible for user account management, access permissions, and system integrations, including the organization's identity provider.
5. Users and Roles
    a. Employees (Standard Users):
        i. Regular users includes consultants and general employees. They are who generate the majority of system activity. They use the system to upload, access, and share files required for daily operations with standard access permissions.
    b. Managers/Supervisors:
        i. This will include managers and project leads. These are users with elevated visibility over team-related content. They coordinate collaboration efforts, oversee shared resources, and may have broader access to departmental files based on their role.
    c. System Administrators (IT/Admin):
        i. Responsible for managing system configuration, user accounts, access permissions, and security settings. They ensure the system operates properly and that access is appropriately controlled.
    d. External Users:
        i. Non-organizational users granted limited access to specific files or folders for approved business purposes such as collaboration, document exchange, or communication.
6. Data Types
    a. Internal Data:
        i. Includes internal business documents such as procedures, reports, and operational materials used across teams to support daily business functions.
    b. Business-Sensitive Data:
        i. Includes client and project-related information such as deliverables, contracts, and presentations, where unauthorized disclosure could impact business operations, client relationships, or organizational reputation.
    c. Confidential / Financial Data:

        i. Includes sensitive organizational information such as financial records, budgeting data, and restricted internal reports, where disclosure could result in financial loss or significant business impact.
    d. Personally Identifiable Information (PII):
        i. Includes data that can identify individuals, such as names, email addresses, and contact details, which requires protection due to privacy concerns and potential regulatory implications.
7. System Environment
    a. The Cloud File Sharing System (CFSS) is deployed fully as a Cloud-hosted Software as a Service (SaaS) platform. The third-party vendor is responsible for managing all of the underlying infrastructure including servers and databases. Apex does not hold any of its infrastructure on premise.
    b. Apex Consulting Group is responsible for the system-level configurations such as assigning user roles, permissions, various settings, and integrations. The method assigned for accessing this system is over the internet via browser. Apex's identity provider is integrated with the CFSS to authenticate users. It utilizes SSO and MFA for all users.
8. System Interconnections
    a. The Cloud File Sharing System (CFSS) works with a number of outside systems to make it work. Okta, the organization's identity provider, provides authentication services for the system. These include Single Sign-On (SSO) and Multi-Factor Authentication (MFA). This makes Okta a key part of the system that users need to access.
    b. The CFSS also works with Microsoft 365, the organization's email system, to send notifications about file sharing, access requests, and system alerts. Users can get to the system through endpoint devices like laptops and mobile phones, but these endpoints are not part of the system boundary.
9. System Boundary
    a. The system boundary for the Cloud File Sharing System (CFSS) includes all components and functions that are directly managed and controlled by Apex Consulting Group within the SaaS environment. This includes the use of the application for storing, processing, and sharing organizational and client data, as well as all user and configuration management activities.
    b. In-Scope Components
        i. The following components are within the system boundary:
            1. CFSS application as utilized by the organization
            2. System configuration settings and controls
            3. User account management and access control
            4. Roles, permissions, and privilege assignments
            5. Data stored, processed, and shared within the system

c. External Dependencies (Out of Scope)
    i. The following systems interact with CFSS but are not part of the system boundary:
        1. Okta (Identity Provider) used for authentication, Single Sign-On (SSO), and Multi-Factor Authentication (MFA)
        2. Microsoft 365 (Email System) used for notifications and communication
        3. User endpoint devices (e.g., laptops, mobile devices) used to access the system
d. Excluded Components
    i. The following components are not within the system boundary and are managed by the third-party service provider:
        1. Underlying infrastructure, including servers, databases, and storage
        2. Operating system and runtime environment
        3. Network infrastructure and supporting platform services

10. Control Selection

Control ID	Control Name	Type	Responsibility	Justification
AC-1	Access Control Policy and Procedures	System-Specific	Apex	Apex defines and maintains access control policies governing user access and permissions
AC-2	Account Management	System-Specific	Apex	Apex manages user provisioning, role assignments, and account lifecycle through CFSS and Okta
AC-3	Access Enforcement	System-Specific	Apex	Access to files and system functions is enforced through role-based permissions configured by Apex

AC-5	Separation of Duties	System-Specific	Apex	Apex assigns roles to prevent conflicts of interest and enforce separation of responsibilities
AC-6	Least Privilege	System-Specific	Apex	User access is restricted based on job roles and business need within CFSS
AC-7	Unsuccessful Logon Attempts	Shared	Apex / Vendor	Vendor enforces lockout mechanisms while Apex configures authentication policies via Okta
AC-17	Remote Access	Inherited	Vendor	Vendor controls secure remote access infrastructure and communication mechanisms
IA-1	Identification and Authentication Policy and Procedures	System-Specific	Apex	Apex defines authentication requirements and policies for system access
IA-2	Identification and Authentication (Users)	Shared	Apex / Okta	Okta authenticates users while Apex manages identity assignments and access requirements
IA-5	Authenticator Management	Shared	Apex / Okta	Okta manages credentials and

				MFA while Apex enforces usage policies
IA-7	Cryptographic Module Authentication	Inherited	Vendor	Vendor manages cryptographic modules used for secure authentication processes
AU-1	Audit and Accountability Policy and Procedures	System-Specific	Apex	Apex defines logging and monitoring requirements for system activity
AU-2	Event Logging	Shared	Apex / Vendor	Vendor generates logs while Apex defines which events are logged and monitored
AU-6	Audit Review, Analysis, and Reporting	System-Specific	Apex	Apex reviews logs and analyzes system activity for anomalies and compliance
AU-8	Time Stamps	Inherited	Vendor	Vendor ensures accurate system time synchronization for logs
AU-12	Audit Record Generation	Shared	Apex / Vendor	Vendor generates logs while Apex configures logging requirements
SC-7	Boundary Protection	Inherited	Vendor	Vendor controls network

				boundaries and traffic filtering mechanisms
SC-8	Transmission Confidentiality and Integrity	Inherited	Vendor	Vendor ensures encryption of data in transit (HTTPS/TLS)
SC-12	Cryptographic Key Management	Inherited	Vendor	Vendor manages encryption keys and cryptographic operations
SC-13	Cryptographic Protection	Inherited	Vendor	Vendor enforces encryption mechanisms for data protection
CM-1	Configuration Management Policy and Procedures	System-Specific	Apex	Apex defines configuration management policies for system usage
CM-2	Baseline Configuration	Shared	Apex / Vendor	Vendor maintains system baseline while Apex configures application settings
CM-6	Configuration Settings	System-Specific	Apex	Apex manages system settings such as permissions and configurations
CM-7	Least Functionality	Shared	Apex / Vendor	Vendor provides system capabilities while Apex restricts unnecessary features

AT-2	Security Awareness Training	System-Specific	Apex	Apex provides security awareness training to users of the system
AT-3	Role-Based Training	System-Specific	Apex	Apex ensures users receive training based on their roles
IR-4	Incident Handling	Shared	Apex / Vendor	Vendor handles infrastructure incidents while Apex manages internal response procedures
IR-6	Incident Reporting	System-Specific	Apex	Apex defines and executes incident reporting processes
RA-3	Risk Assessment	System-Specific	Apex	Apex conducts risk assessments for system usage and data handling
RA-5	Vulnerability Monitoring	Shared	Apex / Vendor	Vendor performs infrastructure scanning while Apex monitors system-level risks
SA-4	Acquisition Process	System-Specific	Apex	Apex evaluates and selects vendors based on security requirements
SA-9	External System Services	Shared	Apex / Vendor	Vendor provides services while

				Apex manages vendor relationship and risk
SI-3	Malicious Code Protection	Inherited	Vendor	Vendor implements protections at the infrastructure and platform level
SI-4	System Monitoring	Shared	Apex / Vendor	Vendor provides monitoring capabilities while Apex reviews activity
MA-4	Nonlocal Maintenance	Inherited	Vendor	Vendor performs remote maintenance of the system infrastructure
MP-5	Media Transport	Inherited	Vendor	Vendor controls data transfer mechanisms within the platform
PE-3	Physical Access Control	Inherited	Vendor	Vendor secures physical data center access
PL-2	System Security Plan	System-Specific	Apex	Apex develops and maintains the SSP for the CFSS
PM-9	Risk Management Strategy	System-Specific	Apex	Apex defines organizational risk tolerance and management approach
PS-3	Personnel Screening	System-Specific	Apex	Apex conducts screening for

				employees accessing sensitive systems
CP-2	Contingency Plan	Shared	Apex / Vendor	Vendor ensures system availability while Apex defines business continuity procedures

11. Control Implementation
    a. AC-2 – Account Management
        i. Apex connects Okta and the Cloud File Sharing System (CFSS) to add, change, and remove user accounts. According to the principle of least privilege, users are only given access to what they need to do their job. Management has to give the go-ahead for account creation, and when an employee leaves the company or changes roles, their account is disabled or deleted. Access reviews are done from time to time to make sure that active accounts are still allowed.
    b. AC-6 – Least Privilege
        i. Apex enforces least privilege by only giving users the access they need to do their jobs. CFSS has role-based access controls set up, and permissions are checked on a regular basis to make sure that no one has too much access. Only authorized people can have administrative privileges, and elevated access is only given when it is needed and approved.
    c. AC-7 – Unsuccessful Logon Attempts
        i. To keep accounts secure, CFSS uses Okta to manage logins. Apex sets the specific rules like how many failed attempts are allowed and how long a lockout lasts. This partnership protects against brute-force attacks while ensuring Apex maintains full control over its security policies.
    d. IA-2 – Identification and Authentication (Organizational Users)
        i. Okta is the front door to CFSS, and it gives every user SSO and MFA. Apex keeps track of our identities and makes sure our security standards are met. MFA is enforced to strengthen access security and reduce the risk of unauthorized access.
    e. IA-5 – Authenticator Management
        i. Okta manages user authenticators, including passwords and multi-factor authentication methods. Apex enforces password complexity, rotation

policies, and MFA usage through configuration settings within Okta. Users are required to maintain secure authentication credentials in accordance with organizational policy.

f. AU-2 – Event Logging
    i. CFSS maintains a clear digital record of all activity, including logins and how files are accessed or shared. Apex determines exactly which events need to be tracked to ensure we're meeting our security and monitoring standards. This oversight keeps everyone accountable and makes it much easier to spot and investigate any suspicious behavior.
g. AU-6 – Audit Record Review, Analysis, and Reporting
    i. Apex is in charge of looking over the audit logs that CFSS generates. Logs are reviewed to see if there are any strange user actions, attempts to get into the system without permission, or other issues. Findings are written down and, if necessary, are escalated to the appropriate personnel to help with incident response and compliance work.
h. AU-12 – Audit Record Generation
    i. The CFSS vendor automatically generates audit logs for system activity. Apex configures logging settings to make sure the right events are being captured and periodically checks that the logs are detailed enough to support monitoring and compliance needs.
i. SC-8 – Transmission Confidentiality and Integrity
    i. All data traveling to and from CFSS is protected by secure, vendor-managed encryption. This keeps our information from being intercepted or altered. Apex oversees this by ensuring all user access happens over these verified, secure connections.
j. CM-2 – Baseline Configuration
    i. The vendor is responsible for ensuring that the core system configuration is up to date, which includes the platform's default settings and setup. Apex takes care of application-level settings like user roles, permissions, and access settings. This shared approach keeps the system safe while still meeting the needs of the business.
k. SI-4 – System Monitoring
    i. The vendor provides built-in logging and monitoring features for the system. Apex uses these logs to keep track of what the system is doing and adds any alerts that are important to its own monitoring. This helps find behavior that seems off and helps people respond quickly to possible problems.
l. CP-2 – Contingency Plan
    i. The vendor supports system availability through backups, redundancy, and failover capabilities. Apex develops its own internal procedures to handle

disruptions, including how teams will continue operations and communicate if the system becomes unavailable.

12. Assumptions & Dependencies
    a. There are a number of assumptions and system dependencies that go into judging the Cloud File Sharing System (CFSS). It is assumed that the SaaS provider keeps secure baseline configurations, uses encryption for data both in transit and at rest, and puts in place the right security controls at the infrastructure level. It is also assumed that users follow the rules set by the organization about how to handle data and who can access it.
    b. There are a few important dependencies that the system needs to work well. These are Okta for authentication and access management, Microsoft 365 for email notifications and communication, and user endpoint devices for accessing the system. The CFSS also depends on the third-party vendor environment's availability and security posture, which includes its infrastructure, network, and storage components. If any of these dependencies are broken or weak, it could affect the system's security and availability.
13. Risk Assessment
    a. To get a clear picture of where things could go wrong, the Cloud File Sharing System (CFSS) was reviewed based on how it’s actually used day to day. The focus was on who has access, how files are shared, how system activity is tracked, and how much the system depends on the external SaaS provider. From that, a few common themes came up. There’s a risk of users having more access than they need if roles aren’t reviewed regularly, files being shared more broadly than intended, and system activity not always being watched closely enough to catch issues early.45
    b. Another thing to think about is that the system depends on a third-party vendor. Apex doesn't have full access to everything that happens behind the scenes, even though the vendor takes care of the infrastructure and a lot of the security. That means you need to trust people to some extent, but you also need to have better internal practices to make up for it. The system is at a moderate level of risk overall, which makes sense given how it's set up. However, making access control stricter, monitoring more closely, and being more careful about how users interact with the system would all help lower that risk.

14. Plan of Action & Milestones

The following POA&M summarizes key remediation actions identified during the assessment. A detailed version is maintained separately for tracking and updates.

Weakness	Control	Planned Action	Priority	Timeline
Inconsistent user access reviews and potential for excessive permissions	AC-2, AC-6	Implement a formal quarterly access review process to validate user roles and permissions, and remove unnecessary access	High	30–60 days
Risk of sensitive data exposure due to improper file sharing practices	AC-3, AC-6, SC-8	Restrict file sharing permissions by default, enforce least privilege, and provide user guidance on secure file handling practices	High	30 days
Limited visibility into system activity due to inconsistent log review	AU-6, SI-4	Establish a defined log review schedule and implement alert thresholds for suspicious activity	Medium	60 days
Dependence on third-party vendor for system availability and security controls	CP-2, SA-9	Develop internal contingency procedures and review vendor security posture, including SLAs and security documentation	Medium	60–90 days
Delayed detection of suspicious or malicious activity	AU-6, SI-4	Improve monitoring practices by integrating alerts into internal workflows and ensuring timely response procedures are defined	Medium	60 days

15. Authorization Summary
    a. The Cloud File Sharing System (CFSS) has a moderate level of risk, which is consistent with its system categorization. The assessment found a number of control gaps, mostly having to do with managing access, monitoring practices, and relying on third-party services. These gaps don't mean that security controls don't work at all; they just show where they could be better.
    b. Based on the results of this assessment, it is recommended that the system be considered for conditional authorization, pending the fixing of the weaknesses that were found in the Plan of Action and Milestones (POA&M). The designated

Authorizing Official is still in charge of making final decisions about authorization.